LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

# Daily 2026-10-25 Arista VeloCloud Orchestrator CVE-2026-114625 Exploitation Priority Update

CVE / Vulnerability Threat Intelligence Report

| | |
|---|---|
| **Classification** | TLP:CLEAR |
| **Published** | 2026-10-25 |
| **Version** | 1.0 |
| **Author** | Lost Boys Cyber |
| **Report Type** | CVE / Vulnerability Threat Intelligence Report |



Published: 2026-10-25 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

# Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

# Daily 2026-10-25 Arista VeloCloud Orchestrator CVE-2026-114625 Exploitation Priority Update

## 1. Executive Summary

CVE-2026-114625 is an Arista VeloCloud Orchestrator (VCO) on-premises SQL-injection issue added to CISA's Known Exploited Vulnerabilities catalog on 23 October 2026. CISA's entry states that exploitation can expose privileged internal functionality and affect the VCO host and managed data. NVD records the advisory as published on 22 October and modified on 24 October, making it the highest-priority newly corroborated edge-management exposure reviewed in this run.

VCO is a centralized SD-WAN management plane. Consequently, its compromise can create a high-value control-plane problem even where the appliance itself is not directly internet-facing. Immediately identify every on-premises VCO, confirm whether it is reachable from untrusted networks or delegated administrator segments, apply Arista's fixed release, and retain authentication, administrator-action, API, and host telemetry for retrospective review. The sources support prioritization and active-exploitation handling; they do not identify a victim organization, actor, or a complete public exploit chain.

## 2. Vulnerability Metadata

| Field | Value |
|---|---|
| CVE | CVE-2026-114625 |
| Product | Arista VeloCloud Orchestrator (VCO), on-premises |
| Vulnerability class | SQL injection; access to privileged internal functionality |
| Severity | Critical priority; third-party coverage reports CVSS 9.9, while operators should use the vendor advisory for authoritative scoring and versions |
| Published / updated | 22 October 2026 / 24 October 2026 (NVD) |
| Exploitation status | CISA KEV added 23 October 2026; treat as actively exploited |
| Hosted scope | NVD states hosted and Dedicated versions were already patched; verify the vendor advisory for tenant-specific assurance |

## 3. Source Review & Confidence

| Source | Contribution | Confidence |
|---|---|---|
| CISA KEV | Active-exploitation prioritization and concise impact statement | High |
| NVD CVE API | CVE description, dates, advisory linkage, and hosted-service note | High |
| Arista Security Advisory 0199 | Canonical product, version, remediation, and support scope | High |

The reporting set is mutually consistent about on-premises VCO exposure and response urgency. No source reviewed in this run establishes a public proof of concept, a named threat actor, or customer compromise. Those claims are intentionally excluded.

## 4. Vulnerability Details

NVD describes a condition in which an authenticated user of an affected system can gain operator privileges and masquerade as a local superuser operator, accessing functionality intended for internal use. CISA characterizes the flaw as SQL injection capable of providing remote access to privileged internal functionality. The management-plane role of VCO increases impact: an attacker who gains elevated orchestration access may alter or inspect operational configuration and potentially affect managed SD-WAN estate administration. Exact affected and fixed releases must be taken from Arista Advisory 0199 before change execution.

## 5. Attack Scenarios

- A compromised or low-privilege VCO account reaches an exposed management interface and attempts privilege escalation through crafted requests.
- A trusted administration segment is accessed through stolen identity credentials; the intruder uses VCO functions to enumerate or modify high-value control-plane configuration.
- An organization patches the appliance but leaves API gateways, jump hosts, or administrator identities exposed, enabling post-remediation reuse of stolen access.

## 6. Threat Landscape & Exploitation Status

CISA KEV inclusion is sufficient to place this issue in emergency remediation and incident-hunting workflows. It is not evidence that every VCO tenant is compromised. Treat unusual administrator role changes, superuser-like actions, configuration export, tenant enumeration, API activity, and appliance shell/process events as investigation leads, not conclusive indicators of this CVE.

## 7. Affected Products and Exposure

| Exposure pattern | Priority | Defender action |
|---|---|---|
| Internet-reachable on-prem VCO | Critical | Restrict management exposure immediately, apply vendor fix, and review access/activity logs |
| VCO reachable from broad corporate or partner networks | Critical | Segment administration, require MFA/jump-host access, and validate account roles |
| Hosted or Dedicated VCO | High | Obtain tenant-specific vendor confirmation and audit privileged access; do not assume equivalence with on-prem scope |
| Patched VCO with retained privileged sessions | High | Rotate/revalidate high-privilege sessions and investigate activity during the exposure window |

## 8. Mitigation and Workarounds

1. Inventory all VCO deployments, management URLs, versions, and reachable networks; prioritize on-premises instances.
2. Apply the fixed release specified by Arista Security Advisory 0199 under expedited change control and record the resulting version.
3. Remove direct internet exposure where operationally feasible; permit administrative access only through authenticated, logged management paths.
4. Review and reduce local/operator accounts, API tokens, federation roles, break-glass accounts, and unmanaged service credentials.
5. Preserve VCO audit/API/configuration logs and appliance EDR or syslog evidence before upgrades or cleanup.

6. Validate post-patch access controls using a non-production or approved administrative test; this report does not authorize exploitation testing.

## 9. Detection Engineering

| Signal | Telemetry | Analytic goal |
|---|---|---|
| Privilege/role change or superuser-like action | VCO audit logs, IdP logs | Identify anomalous elevation or account manipulation |
| Large configuration export or tenant/device enumeration | VCO API/audit logs, proxy logs | Find control-plane discovery and staging |
| Administrative API activity from atypical source | VCO API logs, VPN, proxy, IdP | Identify account abuse or unexpected management access |

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any ("velocloud", "vco") or RemotePort in (443, 8443)
| where InitiatingProcessAccountName !in ("", "SYSTEM")
| summarize Connections=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName,
InitiatingProcessAccountName, RemoteUrl, RemoteIP
| order by Connections desc
```

## 10. Threat Hunting

**Hypothesis:** An attacker exploiting or preparing to exploit the VCO management plane will produce unusual privileged access, role changes, configuration retrieval, or API request patterns before downstream network changes occur.

```
DeviceEvents
| where Timestamp > ago(30d)
| where AdditionalFields has_any ("superuser", "operator", "role", "configuration", "export", "api")
| project Timestamp, DeviceName, ActionType, InitiatingProcessAccountName, AdditionalFields
| order by Timestamp desc
```

Validate every hit with VCO audit records and an approved administrator/change window. Generic endpoint telemetry cannot prove application-layer exploitation.

## 11. MITRE ATT&CK Mapping

| Technique | Name | Rationale |
|---|---|---|
| T1190 | Exploit Public-Facing Application | Exposure hypothesis for reachable VCO management interfaces |
| T1078 | Valid Accounts | Relevant to authenticated privilege escalation and abused administrator access |
| T1098 | Account Manipulation | Hunt target for unexpected role/account changes |

## 12. Validation / Lab Testing

No exploit was executed and no production appliance was scanned. Validation consisted of source corroboration, vendor/NVD/CISA review, and analytic review. Operators should validate the installed version and access-control changes in an approved environment.

## 13. Recommended Actions Summary

| Priority | Owner | Action |
|---|---|---|

| | | |
|---|---|---|
| Critical | Network platform owner | Identify and patch every on-prem VCO using Advisory 0199 |
| Critical | Network security | Remove unnecessary management exposure and restrict administrative paths |
| High | SOC | Hunt VCO audit/API logs for role, export, and anomalous administrative activity |
| High | IAM | Revalidate privileged accounts, tokens, federation, and break-glass access |

## 14. References

See `sources.md` and `references.md` for source URLs and scope limitations.